

Autenticação e Autorização

Programação para a Web 2

Aula 11

Evandro J.R. Silva

Introdução

- A **autenticação** é o processo de **verificar a identidade** de um **usuário** ou **sistema** para garantir que ele é quem afirma ser. Por exemplo, precisamos nos autenticar antes de
 - Embarcar em um avião ou ônibus;
 - Acessar a área de treino de uma academia;
 - Acessar partes sensíveis de um sistema;
 - Votar.

Introdução

- Não confundir com **Autorização**

	Autenticação	Autorização
Propósito	Verificar a identidade do usuário	Determinar as permissões do usuário
Exemplo	<i>Login com senha ou biometria</i>	Acesso a arquivos ou recursos
Quando acontece	Primeiro passo	Após a autenticação

Introdução

- **Fatores**

- Existem três fatores de autenticação:
 - **Fator de conhecimento:** algo que você sabe (senhas, PINs, perguntas de segurança);
 - **Fator de posse:** algo que você possui (tokens físicos USB, smartphone para receber SMS ou OTP, chaves criptográficas, etc.);
 - **Fator de qualidade/inerência:** algo que você é (biometria como impressão digital, reconhecimento facial, de íris ou voz).
- Classificação da autenticação de acordo com os fatores
 - **Autenticação de Único Fator** (SFA — *Single-Factor Authentication*): utiliza apenas um fator;
 - **Autenticação de Dois Fatores** (2FA — *Two-Factor Authentication*): utiliza dois fatores;
 - **Autenticação Multifator** (MFA — *Multifactor Authentication*): utiliza dois ou mais fatores.

Protocolos, métodos e processos

- **Protocolo de autenticação (as regras)**
 - Uma estrutura subjacente, geralmente programática, que define como os sistemas se comunicam e verificam identidades com segurança. Ela estabelece uma “linguagem” para verificação.
- **Método de autenticação (o mecanismo)**
 - A forma específica pela qual um usuário comprova sua identidade, geralmente em conjunto com um protocolo. Essas formas são categorizadas como algo que você sabe (senha), possui (*token*) ou é (biometria).
- **Processo de autenticação (o procedimento)**
 - O procedimento completo, passo-a-passo, para verificar um usuário, que pode incluir o protocolo, o método e o fluxo de trabalho do usuário.

Protocolos, métodos e processos

- Apesar dos três conceitos apresentados no slide anterior, o que se encontra a partir de uma pesquisa é que os termos são utilizados intercambiavelmente, ou seja, sem grandes distinções.
 - Em vários casos o **protocolo** e o **método** são tratados como a mesma coisa.
 - Uma possível razão é a descrição do **protocolo** permitir apenas sua implementação por completo, ou seja, não há a possibilidade de dois ou mais **métodos** para um mesmo **protocolo**. O mesmo ocorre entre **método** e **processo**.

Protocolos, métodos e processos

- Os métodos/processos mais comuns
 - **Password-Based:** baseados em envio direto ou uso de senhas/segregos.
 - **Challenge-Based:** autenticação baseada em desafio (o servidor envia um desafio, o cliente responde com um cálculo).
 - **Token-Based:** baseados em *tokens* de acesso (geralmente emitidos após login, usados em APIs/rotas).
 - **Certificate-Based:** autenticação baseada em certificados digitais.
 - **2FA/MFA:** métodos que combinam dois ou mais fatores de autenticação.
 - **Adaptive MFA:** consiste em um MFA que requer fatores adicionais ou diferentes baseados no contexto que envolve uma solicitação de login ou acesso.
 - **Phishing-resistant MFA:** utiliza chaves criptográficas associadas a sites legítimos para verificar a identidade de um usuário de uma forma que resista à interceptação, à reprodução ou à manipulação social (*social engineering*).

Protocolos, métodos e processos

- Os métodos/processos mais comuns (continuação)
 - **Session-Based:** Autenticação baseada em sessões mantidas no servidor (*cookies*, identificadores de sessão).
 - **Passwordless:** Autenticação sem uso de senha, baseados em dispositivo, biometria, etc.
 - **Autenticação por biometria:** Autenticação feita por impressão digital, reconhecimento facial, íris, voz etc.
 - **Hardware tokens:** Dispositivos USB/NFC que realizam login por chave pública ou provas de posse.
 - **Link Mágico:** Envio de link único para login para o e-mail cadastrado.
 - **Behavioral:** analisa os padrões únicos de uma atividade de usuário, como o movimento de mouse, uso do *touchscreen* e velocidade de digitação.
 - **CAPTCHA** (*Completely Automated Public Turing Test*)

Protocolos, métodos e processos

- Alguns dos métodos/protocolos
 - [PAP](#) (*Password Authentication Protocol*)
 - [CHAP](#) (*Challenge-Handshake Authentication Protocol*)
 - [EAP](#) (*Extensible Authentication Protocol*)
 - Consistem em um *framework* geral para autenticação cliente-servidor. Possui muitas variações.
 - Atualmente é amplamente utilizado nos padrões IEEE 802.3, IEEE 802.11 (WiFi) ou IEEE 802.12.
 - TACACS+ (*Terminal Access Controller Access-Control System*)
 - RADIUS (*Remote Authentication Dial-In User Service*) e DIAMETER.
 - [Kerberos](#)

Protocolos, métodos e processos

- Alguns dos métodos/protocolos
 - LDAP (*Lightweight Directory Access Protocol*)
 - Definido no [RFC 4510](#), serve como padrão fundamental para autenticação em serviços de diretório.
 - Basic Authentication
 - É o esquema de autenticação do HTTP, especificado no [RFC 7617](#).
 - SAML (*Security Assertion Markup Language*)
 - Fornece uma estrutura baseada em XML para troca de dados de autenticação e autorização em ambientes federados. Tem suporte para o **SSO** (*Single Sign-On*).
 - Os **Padrões de Federação de Identidade** permitem o SSO em domínios confiáveis, permitindo que um provedor de identidade (**IdP** – *Identity Provider*) autentique usuários e emita declarações de segurança que os provedores de serviços (**SPs** – *Service Providers*) confiam para conceder acesso, sem trocar credenciais de usuário diretamente.

Protocolos, métodos e processos

- Alguns dos métodos/protocolos
 - OAuth (*Open Authentication*)
 - O OAuth 2.0, especificado no [RFC 6749](#), serve como uma estrutura de autorização principalmente para delegar acesso a APIs em nome de um proprietário de recurso, embora indiretamente suporte autenticação em cenários federados.
 - OIDC (*OpenID Connect*)
 - É baseado no OAuth 2.0 como uma camada de autenticação para verificar a identidade do usuário final, produzindo tokens de ID no formato JSON Web Token (JWT).
 - TLS (*Transport Layer Security*)
 - Faz parte dos protocolos de certificado e PKI (*Public Key Infrastructure*).

Protocolos, métodos e processos

- Alguns dos métodos/protocolos
 - OTP (*One-Time Password*), TOTP (*Time based OTP*) e HOTP (*HMAC based OTP*)
 - OTPs são códigos temporários, normalmente utilizados uma única vez, sendo utilizado como uma camada a mais na autenticação.
 - TOTPs são códigos que possuem normalmente 6 dígitos, gerados por aplicativos autenticadores, e costumam ser válidos por poucos segundos.
 - HOTPs são comumente encontrados em *hardware tokens*. Os códigos gerados não expiram com o tempo, e permanecem válidos até que sejam usados ou outro código seja gerado.
 - FIDO (*Fast Identity Online*)
 - Conjunto de padrões abertos definidos pela [FIDO Alliance](#) que elimina o uso de senhas tradicionais, permitindo logins mais rápidos e seguros.

Autorização

- Alguns dos tipos de sistema de autorização:
 - **RBAC** (*Role-Based Access Control*)
 - **ABAC** (*Attribute-Based Access Control*)
 - Se utiliza de atributos baseados no ambiente, ação, objetos, etc.
 - **ACL** (*Access Control List*)
 - **DAC** (*Discretionary Access Control*)
 - O acesso é determinado pelo dono do recurso.
 - **MAC** (*Mandatory Access Control*)
 - Uma autoridade central (ex.: uma política de segurança) determina o acesso.